CASE STUDY

The Shadow Brokers and Vault 7: The NSA and CIA Tool Leaks, 2016 to 2017

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

The people who paid for the 2016 and 2017 tool leaks mostly never heard of the leakers. They were patients in England whose hospital appointments were cancelled in May 2017: the UK National Audit Office found at least 81 of the 236 NHS trusts in England and 603 other NHS organisations, 595 of them GP practices, infected by WannaCry, with 6,912 cancelled appointments recorded and more than 19,000 estimated (Confirmed [44]). They were the staff of the health system, shipping firm and drug maker that a US grand jury says lost nearly $1 billion between them to NotPetya six weeks later (Confirmed [52], indictment allegations). And they were the network teams who spent years after 2017 patching and retiring a file-sharing protocol, SMBv1, that Microsoft had already asked them to stop using (Confirmed [62][67] that Microsoft had asked; Inferred for the years of remediation, from the exploitation and KEV record [24][73][79]). This study follows the leaks from the first auction post to those costs, and grades every claim by the record that supports it.

Two separate leaks ran side by side. A group calling itself the Shadow Brokers began posting on 13 August 2016 (Confirmed [2]). It offered what it called "Equation Group" files for auction, gave away a sample archive and, after the auction failed, released the archive's passphrase by 8 April 2017, the day a public mirror of the decrypted archive appeared, and a Windows exploit set on 14 April 2017 (Confirmed [3][6], as the group's own posts; Demonstrated [7][9]). Kaspersky, which had named the Equation group in 2015, found the free archive related to Equation malware "with a high degree of confidence" (Confirmed [1][2]). Over the same months WikiLeaks published Vault 7 and Vault 8, internal material from the CIA's Center for Cyber Intelligence, starting on 7 March 2017 (Confirmed [33]). The Department of Justice counts 26 disclosures from the stolen files between March and November 2017 (Confirmed [39]).

The two leaks left very different records. For Vault 7 there is a full court record. A CIA developer, Joshua Adam Schulte, used an administrator session he had secretly kept open to copy the entire tool-development archives on 20 April 2016, deleted hundreds of log files, and sent the files to WikiLeaks; he was convicted of espionage and computer offenses in July 2022 and sentenced to 40 years in February 2024 (Confirmed [39][40]). The CIA's own task force found that it did not know of the loss until WikiLeaks announced it about a year later, and that its security had been "woefully lax" (Confirmed [42]). For the Shadow Brokers there is no such record. No government source opened for this study names who they were. The two prosecutions that public retellings tie to the leak, of the government contractor Harold Martin and the NSA developer Nghia Pho, are retention cases that say nothing about transmission or the group, and the links to them in public retellings come from journalism (Confirmed [28][29]; Reported [31]; Inferred for the gap).

The harm came from reuse, and the patch was early. Microsoft fixed the SMBv1 flaws in MS17-010 on 14 March 2017, a month before the April release, and marked them as neither public nor exploited at the time (Confirmed [15]). WannaCry struck 59 days after the patch and NotPetya 105 days after it (Inferred from [15][20][23]). The US government attributed WannaCry to North Korea and NotPetya to the Russian military; no US government statement opened links either attack to the NSA (Confirmed [46][50]; Inferred [46]). CISA added the six MS17-010 CVEs to its Known Exploited Vulnerabilities catalog between November 2021 and May 2022, all marked as known ransomware use, and a joint advisory, AA24-249A, still recorded EternalBlue use in 2024 (Confirmed [24][79]).

This study is the home for the leak events themselves: the releases, the vendor triage, the Vault 7 prosecution and task force report, the patch-to-worm timeline, the policy argument that followed and the defender view. The Equation platform, the Lamberts and the national attribution question have their home in United States-Attributed Threat Actors; NotPetya has its home in Sandworm: The Operations in the Public Record; the North Korea attribution and government record for WannaCry has its home in North Korea-Attributed Threat Actors, with a short overview in Part 11 of Other State-Linked Threat Actors (Demonstrated [32]). The Zero-Day Trade and Its Fallout holds the zero-day market and the book's view of these years, keeps the WannaCry outbreak in its Part 6 and summarizes the leaks with a link here; Cyber Operations as Statecraft keeps only the dated outline its blowback case needs (Demonstrated [32]).

Key facts at a glance

Item	Detail	Grade
The leakers	"The Shadow Brokers" (NSA-linked tools) and WikiLeaks as publisher of Vault 7 and Vault 8 (CIA tools)	Confirmed [2][33]
Who the Shadow Brokers were	Unresolved: no government record opened names them	Inferred [28][29][31]
Who stole the Vault 7 files	Joshua Adam Schulte, a CIA Center for Cyber Intelligence developer from 2012 to 2016, per the court record	Confirmed [39]
First Shadow Brokers post	13 August 2016 (Kaspersky's date)	Confirmed [2]
Tie to Equation	347 RC5/RC6 implementation instances in the free archive; Kaspersky's "high degree of confidence" that the tools relate to Equation malware	Confirmed [2]
First vendor fixes	Cisco ASA advisories for CVE-2016-6366 (new) and CVE-2016-6367 (fixed since ASA 8.4(3)), 17 August 2016	Confirmed [11][12][13]
The Windows release	"Lost in Translation", 14 April 2017, 08:52:39 UTC	Demonstrated [7]
The patch	MS17-010, 14 March 2017, Critical, six SMBv1 CVEs, marked not public and not exploited at release	Confirmed [15]
Vault 7 start	"Year Zero", 7 March 2017; 26 disclosures from the stolen files through November 2017	Confirmed [33][39]
Size of the CIA loss	At least 180 GB and as much as 34 TB from the development network, per the CIA task force	Confirmed [42]
How the CIA learned of it	From WikiLeaks' announcement, about a year after the theft	Confirmed [42]
Conviction	Schulte: eight counts on 13 July 2022; 40 years on 1 February 2024	Confirmed [40][39]
WannaCry	12 May 2017, 59 days after MS17-010; at least 81 of 236 NHS trusts in England infected	Confirmed [20][44]; Inferred for the interval
NotPetya	27 June 2017, 105 days after MS17-010; spread mainly by credential theft, also by two SMB exploits	Confirmed [23]; Inferred for the interval
Attribution of the reusers	North Korea for WannaCry (19 December 2017); the Russian military for NotPetya (15 February 2018)	Confirmed [46][50]
KEV listing	MS17-010 CVEs added 3 November 2021 to 24 May 2022, all known ransomware use	Confirmed [24]
Policy outcome	Unclassified VEP charter, 15 November 2017; the PATCH Act stopped at referral to committee	Confirmed [59]; Inferred [58]
ATT&CK objects	Group G0020 Equation (no sponsor named); software S0366 WannaCry and S0368 NotPetya; no object for any leaked tool	Confirmed [25][26][27][74]; Demonstrated [77]

Key findings

- **The patch came first.** MS17-010 shipped on 14 March 2017, 31 days before the Shadow Brokers' Windows release, and Microsoft's triage the day after the release found every exploit either already fixed or not reproducible on supported platforms (Windows 7 and later, Exchange 2010 and later) (Confirmed [15][18]). The bulletin credits no finder, and no primary opened says who reported the flaws (Confirmed [15][18]; Inferred for the absence).
- **The damage tracked unpatched and unsupported Windows.** The NAO tied NHS infections to unpatched or unsupported systems, and Microsoft took the "highly unusual step" of shipping the fix for Windows XP, Windows 8 and Windows Server 2003 a day after WannaCry (Confirmed [44][21]).
- **A patched estate was not enough against NotPetya.** CISA found credential theft was NotPetya's primary means of spread, with the SMB exploits used against unpatched hosts (Confirmed [23]; Inferred that patched hosts fell to the credential path).
- **The Vault 7 theft was an insider on an unmonitored network.** The court record and the CIA's own task force describe a developer with residual administrator access, shared administrator passwords, no user activity monitoring, and deleted logs (Confirmed [39][42]).
- **WikiLeaks' framing outran the task force's assessment.** It said the CIA had lost control of the majority of its hacking arsenal; the task force assessed with moderate confidence that WikiLeaks did not hold the better-protected "Gold" folder of final tool versions (Reported [33]; Confirmed [42]; Inferred for the comparison).
- **The tooling was in other hands before the leak.** Symantec found Buckeye (APT3) using a DoublePulsar variant from 31 March 2016, and Check Point found that APT31's "Jian" exploit, whose embedded binary carries an October 2014 timestamp, is a clone of the Equation "EpMe" exploit (Confirmed [69][70]).
- **The tail is long.** ESET saw EternalBlue attempts in April 2018 above the 2017 peaks; KEV listed the MS17-010 set in 2021 and 2022; AA24-249A recorded EternalBlue use by GRU Unit 29155 in 2024; and ATT&CK campaign C0064 records an operator tasking an AI coding agent with an EternalBlue attempt in 2025 or 2026 (Confirmed [73][24][79][80]).
- **Policy changed on paper, modestly.** The US published its Vulnerabilities Equities Process charter in November 2017; its own scope excludes vulnerabilities that are already public, and the PATCH Act never left committee (Confirmed [59]; Inferred [58][59]).

Top recommendations

1. **Retire SMBv1 and keep SMB off the internet.** Remove SMBv1 where in-place upgrades left it behind, and block TCP 445, UDP 137 to 138 and TCP 139 at the boundary, as US-CERT advised in January 2017 (Confirmed [63][67]).
2. **Patch end-of-support systems or isolate them.** The NAO tied the NHS infections to unpatched or unsupported Windows, and Cisco's PIX and FWSM never received a fix for CVE-2016-6366 (Confirmed [44][11]).
3. **Plan for credential-based spread, not only exploits.** Restrict PsExec and WMI, block workstation-to-workstation traffic and keep offline backups, as TA17-181A and TA17-132A advise (Confirmed [23][20]).

4. **Treat a public leak of exploits as an exploitation date.** Patch to the vendor bulletin, not to the KEV date: the MS17-010 set reached KEV between about four and a half and a little over five years after the fix (Confirmed [24]; Inferred for the interval and the rule).
5. **Monitor privileged users on development and build networks.** The task force recommended user activity monitoring and server audit on mission systems, compartmentation and stricter handling of zero-day exploits and offensive tools, and closing gaps in the insider-threat program; shared administrator passwords were among the root causes it named (Confirmed [42]).
6. **Verify firmware and boot integrity on network devices.** Cisco pointed to signed software and Secure Boot against the persistent implant in the 2016 dump (Confirmed [13]).

Scope and method

This study covers the Shadow Brokers' posts and releases from August 2016 to October 2017, WikiLeaks' Vault 7 and Vault 8 publications from March to November 2017, the vendor responses, the prosecution of the Vault 7 source and the CIA task force report, the reuse of the leaked SMB exploits by WannaCry and NotPetya and the attributions that followed, the policy argument over vulnerability stockpiling, and the long tail of exploitation through 2026. It draws on Kaspersky, Cisco, Fortinet, Microsoft, Cisco Talos, Symantec, Check Point, ESET and Countercept research and advisories; CISA and US-CERT alerts, the KEV catalog and NVD; Department of Justice and US Attorney releases; the CIA's public statement and its WikiLeaks Task Force report as released by Senator Ron Wyden; White House, Treasury and UK government statements; the UK National Audit Office; the PATCH Act text and status record; the VEP charter; WikiLeaks' own publication pages; the Shadow Brokers' own posts; one news investigation (POLITICO) and one news report (Al Jazeera); the live MITRE ATT&CK record; and the library's own data files at main 7a45f0a. Every source was opened on 11 November 2026.

Tradecraft is described at the level the advisories use: technique names and ids, CVE ids and vendor bulletin numbers. The study reproduces no exploit code, command, passphrase, payment address or tool internals. Two editorial rules follow from that. First, the Shadow Brokers' own posts, the public repositories that mirror the leaked archives, and leaked documents published by WikiLeaks are cited by their address as plain text, not as links, because they carry passphrases, download pointers or the leaked material itself; WikiLeaks' press and index pages, which describe the releases, are linked. Second, the leakers' posts and WikiLeaks' descriptions are cited for what they say and when, never as proof of what they claim.

Grade	Meaning
Confirmed	A primary source was opened: a vendor advisory or the vendor's own research, a government alert, release or court record, a CVE or KEV record, the MITRE record itself, or a party's own publication for the fact and date that it published
Reported	Known only through a secondary source, or a party's characterization that no primary record supports; attributed where it appears
Demonstrated	This study counted or checked it directly, for example repository metadata, post timestamps or the library's data files
Inferred	This study's own reasoning from the cited facts, labelled where it appears

The study's explicit passage on what is overstated and what is understated is at the end of the Cross-cutting themes section. Where two studies cover the same event, the topic lens names the home and the other study summarizes in one paragraph and links: the routing is in the last paragraph of the Executive summary (Demonstrated [32]).

Part 1: the actors and the record they left

The Shadow Brokers

The name belongs to whoever ran the group's posts; it does not belong to a known person or agency. The group's first message, posted in August 2016 and reposted on its Steemit account on 9 April 2017, announced a bitcoin auction of "Equation Group" files, offered free sample files as proof, and promised a further unencrypted dump if bids reached 1,000,000 BTC (Confirmed [3] that the group posted it; the content is the leakers' claim). Its later posts are the main record of its own conduct: an October 2016 list of IP addresses it said the auction-file tools connected to, a January 2017 offer of "Equation Group Windows Warez", the April 2017 passphrase release and "Lost in Translation", and a run of subscription "dump service" posts through October 2017 (Confirmed [4][5][6][7]; Demonstrated [8]). Part 6 sets out what the record does and does not say about who they were.

Equation, in one paragraph

Kaspersky's Global Research and Analysis Team named the Equation group on 16 February 2015 for its preference for sophisticated encryption, dated its earliest command-and-control domain registration to August 2001 (possibly some from 1996) and its samples to 2002, and described a module able to reprogram hard-drive firmware (Confirmed [1]). ATT&CK records the group as G0020 Equation, v1.2, modified 31 July 2026, with four techniques (T1120, T1480.001, T1542.002 and T1564.005), no software, no aliases and no mention of the NSA or the Shadow Brokers (Confirmed [25]). The platform, its relatives and the question of national attribution are covered in depth in United States-Attributed Threat Actors, which is the home study for Equation (Demonstrated [32]).

The CIA Center for Cyber Intelligence

WikiLeaks described an Engineering Development Group inside the CIA's Center for Cyber Intelligence (CCI), part of the Directorate for Digital Innovation, as the unit that developed and supported the CIA's backdoors, exploits and malware, with about 500 projects and more than 5,000 registered users in the hacking division by the end of 2016 (Reported [33], WikiLeaks' description). The court record confirms the setting in narrower terms: from 2012 to 2016 Schulte was a software developer in CCI and was for a time an administrator of a server and development suite used to build cyber tools (Confirmed [39]). The CIA task force names the network itself, the CCI development network or DevLAN, and two of its parts that WikiLeaks published from, the Stash code repository and the Confluence collaboration platform (Confirmed [42]).

What ATT&CK holds

ATT&CK has no software object for EternalBlue, DoublePulsar or any other leaked Shadow Brokers tool (Confirmed [74]). A search of the library's ATT&CK v20.0 software-to-technique and technique profile files for Shadow Brokers, Vault 7, WikiLeaks, DoublePulsar, EternalBlue and MS17-010 returns no hits (Demonstrated [77]); the individual Vault 7 tool names were not checked. The leaked exploits appear in ATT&CK only as procedure text, mainly under T1210 Exploitation of Remote Services, where entries name EternalBlue, EternalRomance or MS17-010 for twelve groups, software and campaigns (Confirmed [74]). S0690 Green Lambert is attributed by researchers to Longhorn and the Lamberts, but its page does not mention Vault 7; the link from Vault 7 to Longhorn exists in vendor research, not in ATT&CK (Confirmed [78][72]).

Part 2: the timeline

One row per dated event or report. Where an event belongs to another study's home, the row is kept short.

Date	Event	Grade	Source
2010 to 2015-03	Nghia Hoang Pho, an NSA Tailored Access Operations developer from April 2006, removes classified material and keeps it at home	Confirmed	[29]
2014-04-28	White House cybersecurity coordinator Michael Daniel says the US disclosure process has been "reinvigorated" and is biased toward responsible disclosure, and that the government had no prior knowledge of Heartbleed	Confirmed	[56]
2014	Microsoft deprecates SMBv1 publicly, by its own later account	Confirmed	[67]
2014-09-11 to 2014-11-17	Kaspersky's product detects, on a US system, an archive with suspected Equation source code and four classification-marked documents; its CEO orders the archive deleted; the system runs a pirated activation tool carrying a Mokes/SmokeBot backdoor	Confirmed (Kaspersky's own account)	[30]
2014-10	APT31's "Jian" exploit compiled, a clone of the Equation "EpMe" exploit (Check Point)	Confirmed	[70]
2015-02-16	Kaspersky names the Equation group	Confirmed	[1]
2016-03 to 2016-04	Schulte moves branch in March, then gives himself administrator privileges over a project he had been removed from; CCI moves admin rights away from developers and warns him, but he has secretly kept an administrator session open on a server	Confirmed	[39]
2016-03-31	Symantec's earliest date for Buckeye (APT3) use of a DoublePulsar variant, more than a year before the April 2017 release	Confirmed	[69]
2016-04-20	Schulte restores his revoked privileges, copies the entire CCI tool-development archives from the backups, reverts the system and deletes hundreds of log files	Confirmed	[39]

Date	Event	Grade	Source
2016-05-05	Schulte wipes and reformats his home computer after sending the files to WikiLeaks over Tails and Tor	Confirmed	[39]
2016-08-13	The Shadow Brokers leak begins (Kaspersky's date)	Confirmed	[2]
2016-08-13	POLITICO reports a Twitter account prosecutors tie to Harold Martin messaged two Kaspersky researchers about 30 minutes before the dump began, and that Kaspersky tipped off the NSA	Reported	[31]
2016-08	Message #1: the bitcoin auction, free sample files and the 1,000,000 BTC promise	Confirmed (as the group's post)	[3]
2016-08-15	Cisco is alerted to material claiming to come from the Equation Group	Confirmed	[11]
2016-08-16	Kaspersky publishes "The Equation giveaway": 347 RC5/RC6 instances, high-confidence relation to Equation malware	Confirmed	[2]
2016-08-17	Cisco publishes advisories for CVE-2016-6366 and CVE-2016-6367 and a blog naming EXTRABACON, EPICBANANA and JETPLOW; Fortinet publishes FG-IR-16-023 (CVE-2016-6909), which does not mention the leak	Confirmed	[11][12][13][14]
2016-08-19	Cisco finds BENIGNCERTAIN affects only legacy PIX 6.x and earlier	Confirmed	[13]
2016-08-27 to 2016-08-31	Martin's contractor work ends on 27 August; by his plea, he kept classified material through 31 August	Confirmed	[28]
2016-09	Cisco discloses a separate IKEv1 flaw found while investigating BENIGNCERTAIN (advisory cisco-sa-20160916-ikev1; blog update of 21 September)	Confirmed	[13]
2016-09-16	Microsoft's Ned Pyle publishes "Stop using SMB1"	Confirmed	[62]
2016-10	Message #5: a list of IP addresses the group says the auction-file tools connected to	Confirmed (as the group's post)	[4]
2017-01	Message #7: the group says it is selling "Equation Group Windows Warez" and posts screenshots	Confirmed (as the group's post)	[5]
2017-01-16	US-CERT "SMB Security Best Practices", issued in response to public reporting of a potential SMB vulnerability (revised 16 March 2017)	Confirmed	[63]
2017-02-14	Brad Smith proposes a Digital Geneva Convention at the RSA Conference	Confirmed	[53]
2017-03-07	WikiLeaks begins Vault 7 with "Year Zero"	Confirmed	[33]
2017-03-08	The CIA declines to comment on authenticity and warns that such disclosures equip adversaries	Confirmed	[37]
2017-03	FBI search; interviewed, Schulte denies responsibility	Confirmed	[38][39]

Date	Event	Grade	Source
2017-03-14	Microsoft publishes MS17-010	Confirmed	[15]
2017-03-17	NVD publishes CVE-2017-0144; Cisco publishes cisco-sa-20170317-cmp (CVE-2017-3881), found while analyzing Vault 7 documents	Confirmed	[16][71]
2017-03-23	Vault 7 weekly releases begin with Dark Matter	Confirmed	[34]
2017-04-08	A public mirror of the decrypted archive is created at 14:03:59Z; by this date the group had posted "Don't Forget Your Base", calling the auction "an apparent failure" and releasing the passphrase	Demonstrated [9] for the date; Confirmed [6] for the post's content	[6][9]
2017-04-10	Symantec links the Longhorn group's tools to Vault 7 documents	Confirmed	[72]
2017-04-14	"Lost in Translation" posted at 08:52:39 UTC with Windows, Swift and Oddjob archives; a public mirror is created at 11:41:38Z	Demonstrated	[7][10]
2017-04-14	CISA later dates the backdoor in M.E.Doc's software to as early as this day	Confirmed	[23]
2017-04-15	MSRC maps the released exploits to existing fixes; Cisco Talos describes the release and lists Snort coverage; Countercept's DoublePulsar detection script gets its first commit	Confirmed	[18][19][68]
2017-04-17	Snort rules added to the DoublePulsar detection repository	Confirmed	[68]
2017-04-20	Cisco finds no new vulnerabilities affecting Cisco in the April files	Confirmed	[13]
2017-04-21	Vault 7 Weeping Angel release	Confirmed	[34]
2017-05-12	WannaCry; CISA TA17-132A; Microsoft and Talos analyses; Talos sees the first kill-switch requests at 07:24 UTC	Confirmed	[20][64][65]
2017-05-13	Microsoft ships the fix for Windows XP, Windows 8 and Windows Server 2003	Confirmed	[21]
2017-05-14	Microsoft says the exploits were "stolen from the National Security Agency" and calls for governments to report vulnerabilities	Confirmed (as Microsoft's statement)	[22]
2017-05-16	The group posts a WannaCry-themed message	Demonstrated	[8]
2017-05-17	PATCH Act introduced in the Senate and House	Confirmed	[57]
2017-05-30 to 2017-09-06	The group's monthly subscription "dump service" posts, paid in Zcash	Demonstrated	[8]
2017-06-13	Microsoft ships updates for vulnerabilities at "heightened risk of exploitation due to past nation-state activity and disclosures"	Confirmed	[66]

Date	Event	Grade	Source
2017-06-27	NotPetya begins in Ukraine; Microsoft's analysis the same day; CISA TA17-181A on 1 July	Confirmed	[45][23]
2017-08-24	Schulte first arrested	Confirmed	[38]
2017-09-07	Protego, the last Vault 7 weekly release	Confirmed	[34]
2017-09	ESET sees EternalBlue attempts climb again	Confirmed	[73]
2017-10	SMBv1 not installed by default from Windows 10 and Windows Server version 1709	Confirmed	[67]
2017-10-16	"October Price Adjustment", the Shadow Brokers account's last post	Demonstrated	[8]
2017-10-17	CIA WikiLeaks Task Force Final Report	Confirmed	[42]
2017-10-24	Bad Rabbit, which spread with EternalRomance (ATT&CK S0606)	Confirmed	[76]
2017-10-27	UK National Audit Office report on WannaCry and the NHS	Confirmed	[44]
2017-11-09	WikiLeaks begins Vault 8 with Hive source code	Confirmed	[35]
2017-11-15	Unclassified VEP charter published; Rob Joyce's post	Confirmed	[59][60]
2017-12-19	US and UK attribute WannaCry to North Korea	Confirmed	[46][47]
2018-02-15	US and UK attribute NotPetya to the Russian military	Confirmed	[50][51]
2018-04	ESET sees EternalBlue attempts peak above the 2017 highs	Confirmed	[73]
2018-04-17	34 companies sign the Cybersecurity Tech Accord	Confirmed	[54]
2018-06-07	TA17-132A revised to add the North Korea attribution	Confirmed	[20]
2018-06-18	Superseding indictment of Schulte, 13 counts	Confirmed	[38]
2018-09	Symantec reports CVE-2019-0703 to Microsoft	Confirmed	[69]
2018-09-06	Complaint against Park Jin Hyok unsealed; OFAC designates him and his front company	Confirmed (allegations)	[48]
2018-09-25	Pho sentenced to 66 months	Confirmed	[29]
2018-11-29	UK NCSC describes the UK Equities Process	Confirmed	[61]
2019-01-09	POLITICO on Kaspersky, Martin and Pho	Reported	[31]
2019-03-12	Microsoft fixes CVE-2019-0703	Confirmed	[69]
2019-05-06	Symantec publishes its Buckeye findings	Confirmed	[69]
2019-07-19	Martin sentenced to nine years	Confirmed	[28]
2019-09-13	Treasury designates Lazarus Group, Bluenoroff and Andariel	Confirmed	[49]

Date	Event	Grade	Source
2020-03-09	Schulte's first trial ends with contempt and false-statement convictions	Confirmed	[39]
2020-06-16	Senator Wyden releases the redacted task force report	Reported	[43]
2020-06-24	Date of the Lucifer reference ATT&CK cites for EternalBlue and EternalRomance use	Confirmed	[81]
2020-10-19	Six GRU Unit 74455 officers charged, including over NotPetya	Confirmed (allegations)	[52]
2021-02-22	Check Point publishes the story of Jian	Confirmed	[70]
2021-11-03	KEV adds CVE-2017-0143 and CVE-2017-7269	Confirmed	[24]
2022-02-10	KEV adds CVE-2017-0144 and CVE-2017-0145	Confirmed	[24]
2022-03-25	KEV adds CVE-2017-0146 and CVE-2017-3881	Confirmed	[24]
2022-04-06	KEV adds CVE-2017-0148	Confirmed	[24]
2022-05-23	KEV adds CVE-2019-0703	Confirmed	[24]
2022-05-24	KEV adds CVE-2017-0147, CVE-2016-6366, CVE-2016-6367 and CVE-2017-0005	Confirmed	[24]
2022-07-13	Schulte convicted on eight counts at retrial	Confirmed	[40]
2023-09-13	Schulte convicted on three child sexual abuse material counts at a third trial	Confirmed	[41]
2024-02-01	Schulte sentenced to 40 years	Confirmed	[39]
2024-09-05	AA24-249A lists "Use of EternalBlue" by GRU Unit 29155	Confirmed	[79]
2025-12 to 2026-02	ATT&CK campaign C0064 records an AI coding agent tasked with an EternalBlue attempt	Confirmed	[80]
2026-07-31	ATT&CK G0020 Equation last modified (v1.2), still naming no sponsor	Confirmed	[25]

Part 3: the Shadow Brokers releases

August 2016: the auction and the firewall exploits

The first release was aimed at network edge devices (Confirmed [11][13]). Cisco was alerted on 15 August 2016 and published two advisories two days later (Confirmed [11]). CVE-2016-6366 was an SNMP remote code execution flaw in the ASA, which Cisco called a newly found defect, rated CVSS base 8.5 and classed as CWE-119 (Confirmed [11][13]). CVE-2016-6367 was an ASA command-line flaw, also CWE-119, already fixed in ASA 8.4(3) and 9.0(1) (Confirmed [12][13]). Both advisories say the exploit "was publicly disclosed by the alleged Shadow Brokers group" (Confirmed [11][12]). Cisco's blog named the exploits EXTRABACON and EPICBANANA and a persistent implant, JETPLOW; it dated the files to around 2013 or earlier, published Snort rule 3:39885 and IPS signature 7655-0, and pointed to signed software and Secure Boot as the mitigation for JETPLOW-type persistence (Confirmed [13]).

Cisco's follow-up work widened the set. On 19 August 2016 it found that BENIGNCERTAIN affected only legacy PIX 6.x and earlier, and its investigation of that PIX-targeting tool led to a separate IKEv1 memory-disclosure advisory, cisco-sa-20160916-ikev1 (Confirmed [13]). PIX and the Firewall Services Module were past end of support and received no fix for CVE-2016-6366; the workaround was to restrict SNMP access and change community strings (Confirmed [11]).

Fortinet published FG-IR-16-023 on the same day, a cookie-parser buffer overflow, CVE-2016-6909, in FortiOS 4.3.8 and below, 4.2.12 and below and 4.1.10 and below, and in FortiSwitch 3.4.2 and below (Confirmed [14]). The advisory does not mention the Shadow Brokers or the Equation Group (Confirmed [14]). Its connection to the dump exists only in press coverage this study did not open, so it is not counted here as a Shadow Brokers disclosure (Reported, not checked).

Kaspersky tied the free archive to its Equation research the day before the vendor advisories. It found 347 RC5/RC6 implementation instances in the archive, more than 300 files using the Equation-specific RC6 variant in 24 forms, matching 20 compiled versions in Equation malware, including the same unusual subtraction of a negated key-setup constant (Confirmed [2]). It concluded "with a high degree of confidence" that the leaked tools are related to Equation Group malware, and also said it could not determine the attacker's identity or motivation or how the trove was obtained (Confirmed [2]; Reported [2] for the limits of its own assessment).

October 2016 to January 2017: lists and sales

In October 2016 the group posted a list of IP addresses that it said the auction-file tools connected to, servers it called "pitchimpairs" (Confirmed [4] as the group's post; the content is its claim). In January 2017 it said it was now selling "Equation Group Windows Warez" and posted screenshots as proof (Confirmed [5], as the group's post). US-CERT's "SMB Security Best Practices" alert followed on 16 January 2017, issued in response to public reporting of a potential SMB vulnerability; it advised disabling SMBv1 and blocking SMB at the network boundary and does not name the Shadow Brokers (Confirmed [63]). The link between the two is timing only (Inferred [5][63]).

April 2017: the passphrase and "Lost in Translation"

By 8 April 2017, the date a mirror gives for the Medium original (not opened), the group had posted "Don't Forget Your Base", calling its auction "an apparent failure" and releasing the auction file's passphrase as a protest (Confirmed [6]; the Steemit copy was created on 9 April). A public GitHub mirror of the decrypted archive was created at 14:03:59 UTC the same day (Demonstrated [9]). Six days later, at 08:52:39 UTC on 14 April 2017 by the Steemit API, "Lost in Translation" pointed to archives labelled Windows, Swift and Oddjob, and a public mirror of the decrypted archives appeared at 11:41:38 UTC (Demonstrated [7][10]). Both mirrors are cited here by repository metadata only.

Microsoft answered the next day. Its MSRC post, signed by Phillip Misner and dated 15 April 2017 on the page though widely cited as 14 April, mapped each Windows exploit in the release to a fix (Confirmed [18]):

Exploit name in the release	Microsoft's finding	Grade
EternalBlue, EternalChampion, EternalRomance, EternalSynergy	Fixed by MS17-010 (14 March 2017)	Confirmed [18]
EmeraldThread	Fixed by MS10-061	Confirmed [18]

Exploit name in the release	Microsoft's finding	Grade
EducatedScholar	Fixed by MS09-050	Confirmed [18]
EclipsedWing	Fixed by MS08-067	Confirmed [18]
EsikmoRoll	Fixed by MS14-068	Confirmed [18]
ErraticGopher	Fixed before Windows Vista (CVE-2017-8461, added in the post's 13 June 2017 update)	Confirmed [18]
EnglishmanDentist, EsteemAudit, ExplodingCan	Do not reproduce on supported platforms; a 13 June 2017 update to the post pairs EnglishmanDentist with CVE-2017-8487, EsteemAudit with CVE-2017-0176 and ExplodingCan with CVE-2017-7269	Confirmed [18]

The post does not say who reported the flaws fixed by MS17-010 (Confirmed [18]). Cisco Talos, writing on 15 April, said the release contained Windows exploits, Lotus Domino exploits and an exploitation framework, that Talos already had detection for two of the SMB exploits, that some exploits appeared to target zero-days, and listed Snort SIDs 41978, 42255 and 42256 (Confirmed [19]). The Talos URL carries a 2016 path, but the page it serves is the 15 April 2017 post (Confirmed [19]). Cisco's own blog found no new vulnerabilities affecting Cisco in the April files (Confirmed [13]).

The defensive community moved fast. Countercept's DoublePulsar detection script was first committed on 15 April 2017, one day after the dump, with Snort rules added on 17 April. It sweeps a network for the implant over SMB and RDP by re-implementing its unauthenticated ping, and its SMB script can remotely uninstall the implant; the repository now sits under WithSecureLabs (Confirmed [68]).

After April: the subscription posts

The account kept posting. A WannaCry-themed post on 16 May 2017, monthly subscription "dump service" posts paid in Zcash from 30 May to 6 September 2017, and an "October Price Adjustment" on 16 October 2017, the account's last post (Demonstrated [8]). Cisco's 20 April update is the last vendor triage in the opened record; no vendor primary opened describes any tool released through the subscription posts (Confirmed [13]; Inferred for the absence).

Part 4: Vault 7 and Vault 8

What WikiLeaks published

WikiLeaks began Vault 7 on 7 March 2017 with "Year Zero" (Confirmed [33]). By its own count Year Zero held 8,761 documents and files (7,818 of them web pages, with 943 attachments), and it made 70,875 redactions of names, email addresses and IP addresses (Reported [33]). Its press release said the material came from an isolated network inside the CIA Center for Cyber Intelligence, that the CIA had lost control of the majority of its hacking arsenal, and that the archive appeared to have circulated without authorization among former US government hackers and contractors, one of whom supplied portions (Reported [33]). The court record later attributed the theft to one CIA developer (Confirmed [39]).

The rest of the press release is WikiLeaks' account of the documents, graded here as its claims:

- **Android zero-days.** As of 2016 the CIA held 24 weaponized Android zero-days, some developed in house and some obtained from GCHQ, the NSA and contractors (Reported [33]).
- **Weeping Angel.** An Embedded Devices Branch attack on Samsung smart TVs that put the set into a "Fake-Off" mode to record room audio, developed with the UK's MI5/BTSS (Reported [33]). The published Weeping Angel "Extending" user guide is dated 28 February 2014, carries a "SECRET STRAP 2 UK EYES ONLY" marking, and covers an implant's configuration, installation, audio exfiltration and uninstallation (Confirmed [36], as published).
- **Project names.** UMBRAGE, a library of borrowed techniques that WikiLeaks framed as attribution misdirection; Fine Dining, decoy applications; Improvise (JQJIMPROVISE); HIVE, multi-platform implant command and control; Brutal Kangaroo, Hammer Drill, Assassin and Medusa (Reported [33]).
- **Frankfurt and vehicles.** The US consulate in Frankfurt as a covert base for CIA hackers (Center for Cyber Intelligence Europe), and CIA interest, as of October 2014, in infecting vehicle control systems; WikiLeaks added assassination speculation that no primary record supports (Reported [33]).

WikiLeaks' Vault 7 index then lists weekly releases from Dark Matter on 23 March 2017 through Marble, Grasshopper, Hive, Weeping Angel (21 April), Scribbles, Archimedes, AfterMidnight, Athena, Pandemic, CherryBlossom, Brutal Kangaroo, Elsa, OutlawCountry, BothanSpy, Highrise, UCL/Raytheon, Imperial, Dumbo, CouchPotato, ExpressLane and Angelfire, to Protego on 7 September 2017 (Confirmed [34] for the sequence and dates; the tool descriptions on those pages are WikiLeaks'). Vault 8 began on 9 November 2017 with Hive source code and development logs; Hive is covert command and control in which cover domains relay HTTPS traffic to a hidden back end and implants authenticate to a separate gateway (Confirmed [35]). WikiLeaks said Hive's source shows implant certificates generated to impersonate existing entities, with examples appearing to come from Kaspersky Laboratory in Moscow (Reported [35]).

The Department of Justice counts 26 disclosures from the stolen files between March and November 2017, published under the names Vault 7 and Vault 8 (Confirmed [39]). By 17 October 2017 the CIA task force counted descriptions of 35 tools (Confirmed [42]).

The CIA's response

On 8 March 2017 the CIA declined to comment on the authenticity of the documents or on the source. It said it is barred from, and does not conduct, electronic surveillance of individuals in the United States, and warned that such disclosures equip adversaries (Confirmed [37]).

What vendors found

Ten days after Year Zero, Cisco published cisco-sa-20170317-cmp for CVE-2017-3881, a flaw in the Cluster Management Protocol over Telnet in IOS and IOS XE, mostly on Catalyst switches, which it says was found during the analysis of documents related to the Vault 7 disclosure (Confirmed [71]). There was no workaround; Cisco advised disabling Telnet in favor of SSH or restricting it with VTY or infrastructure access lists (Confirmed [71]). CISA added CVE-2017-3881 to KEV on 25 March 2022 (Confirmed [24]).

Symantec, on 10 April 2017, linked the tools of a group it calls Longhorn to Vault 7 documents. Corentry's version history and a February 2015 compiler change from GCC to MSVC match the Fluxwire changelog; Plexor matches the Archangel "Fire and Forget" specification; and the command-and-control and secure-erase tradecraft also match (Confirmed [72]). Symantec counted 40 targets in at least 16 countries and published detections Backdoor.Plexor, Trojan.Corentry and Backdoor.Trojan.LH1 and LH2 (Confirmed [72]).

The Lamberts and Longhorn are covered as a platform in United States-Attributed Threat Actors (Demonstrated [32]).

Part 5: the insider and the court record

How the files left the CIA

The court record is specific (Confirmed [39] unless noted):

1. **Access.** From 2012 to 2016 Schulte was a CCI developer and was temporarily an administrator of a server and development suite used to build cyber tools.
2. **Residual privilege.** After a branch move in March 2016, in April 2016 he gave himself administrator privileges over a project he had been removed from. CCI moved administrator rights away from developers and warned him, but he had secretly kept an administrator session open on a server.
3. **The copy.** On 20 April 2016 he used that session to restore his revoked privileges, accessed the backups, copied the entire CCI tool-development archives, reverted the system and deleted hundreds of log files.
4. **The transfer.** He sent the files to WikiLeaks from his home computer using Tails and Tor, and on 5 May 2016 wiped and reformatted that computer's drives.
5. **The cover story.** Interviewed by the FBI in March 2017, he denied responsibility and offered false accounts of how the files could have left CIA systems.
6. **From detention.** About April 2018 he sent a protected warrant affidavit to reporters; in summer and fall 2018 he used contraband cellphones to plan what he called an "information war", tried to send discovery to WikiLeaks and emailed a reporter classified information about the CCI development network.

DOJ calls the theft the largest data breach in CIA history and says it cost the CIA hundreds of millions of dollars; a former CIA Deputy Director of Digital Innovation called it a "digital Pearl Harbor" at trial (Confirmed [39]).

The prosecution

Date	Step	Grade	Source
2017-03	FBI search	Confirmed	[38]
2017-08-24	First arrest	Confirmed	[38]
2018-06-18	13-count superseding indictment: theft of classified CIA material and transmission to "Organization-1", plus computer, false-statement, obstruction, child-exploitation-material and copyright counts	Confirmed	[38]
2020-03-09	First trial ends with convictions for contempt of court and material false statements	Confirmed	[39]
2022-07-13	Retrial: convicted on eight counts covering national defense information, unauthorized computer access and two counts of causing transmission of harmful computer commands; the US Attorney calls it "one of the most brazen and damaging acts of espionage in American history"	Confirmed	[40]
2023-09-13	Third trial, before US District Judge Jesse M. Furman: convicted on three child sexual abuse material counts (receipt, possession, transportation)	Confirmed	[41]
2024-02-01	Sentenced to 40 years in prison and lifetime supervised release	Confirmed	[39]

The justice.gov releases served a bot interstitial, so the four SDNY releases were read from Internet Archive captures of the same pages; the Sources table gives the original address and the capture date for each (Demonstrated). The appeal outcome was not checked.

The CIA's own review

The WikiLeaks Task Force Final Report of 17 October 2017, released in redacted form by Senator Ron Wyden, is the CIA's own account (Confirmed [42]; Reported [43] for the release date of 16 June 2020). It calls the Vault 7 announcement the largest data loss in CIA history and assesses that in spring 2016 a CIA employee stole at least 180 GB and as much as 34 TB from DevLAN; the exact scope could not be fixed because DevLAN lacked user activity monitoring (Confirmed [42]). The spring 2016 date fits the court record's 20 April 2016 (Inferred [39][42]).

The report says the CIA did not know of the loss until WikiLeaks announced it in March 2017, about a year later, and that a state adversary that stole the data without publishing it might still be undetected (Confirmed [42]). It names the root causes (Confirmed [42]):

- day-to-day security had become "woefully lax";
- most sensitive cyber weapons were not compartmented;
- users shared systems-administrator passwords;
- removable media was not effectively controlled;
- historical data stayed available indefinitely;
- no mitigation packages had been prepared for exposed tools;
- mission "shadow IT" ran outside enterprise governance.

WikiLeaks had released material from DevLAN's Stash repository and Confluence platform, but the task force assessed with moderate confidence that WikiLeaks did not hold the better-protected "Gold" folder of final tool

versions, several terabytes in size (Confirmed [42]). Its recommendations include user activity monitoring and server audit on mission systems, compartmentation and stricter handling of zero-day exploits and offensive tools (Recommendation A5), and closing gaps in the insider-threat program (Confirmed [42]). Releasing it, Wyden wrote that the lax practices were not limited to one part of the intelligence community; the CIA declined to comment on the report (Reported [43]).

Part 6: who leaked the NSA tools

The Shadow Brokers' identity is unresolved in the opened record (Inferred [28][29][31]). Three strands appear in public retellings, and each rests on a different kind of source.

Harold Thomas Martin III. The Department of Justice says he worked as a contractor from December 1993 to 27 August 2016, admitted stealing and keeping classified material from the late 1990s through 31 August 2016, and on 19 July 2019 was sentenced to nine years in prison and three years of supervised release for willful retention of national defense information (Confirmed [28]). The release says nothing about transmission or the Shadow Brokers (Confirmed [28]). POLITICO reported in January 2019 that Kaspersky tipped off the NSA about Martin after a Twitter account prosecutors tie to him messaged two of its researchers on 13 August 2016, about 30 minutes before the dump began (Reported [31]). The same report says he was not charged with espionage, that prosecutors never indicated he had contact with the group, and that the group kept publishing after his arrest, "discounting theories" that he was the Shadow Brokers (Reported [31]).

Nghia Hoang Pho. The Department of Justice says he was an NSA Tailored Access Operations developer from April 2006, removed classified material from 2010 through March 2015 and kept it at home, and on 25 September 2018 was sentenced to 66 months and three years of supervised release for willful retention; the Assistant Attorney General said his conduct rendered some capabilities unusable (Confirmed [29]). The release does not mention the Shadow Brokers, Kaspersky or any leak (Confirmed [29]).

The Kaspersky detection. Kaspersky's own account says that between 11 September and 17 November 2014 its product detected, on a US system, an archive with suspected Equation source code and four classification-marked documents; its CEO ordered the archive deleted; and the system was running a pirated activation tool carrying a Mokes/SmokeBot backdoor (Confirmed [30], as Kaspersky's account). The report does not mention the Shadow Brokers (Confirmed [30]). POLITICO reports that the machine was Pho's home computer and that Kaspersky's software uploaded Equation-related material from it (Reported [31]).

Read together, the record shows two retention cases and one antivirus detection, none of them tied by a primary source to the Shadow Brokers' releases (Inferred). The national-attribution question for the Equation platform itself belongs to United States-Attributed Threat Actors.

Part 7: from leak to worm

WannaCry, in one paragraph

WannaCry began spreading on 12 May 2017, 59 days after MS17-010 (Confirmed [20][15]; Inferred for the interval). It reused the leaked exploit: CISA's alert TA17-132A says it spread through the SMBv1 flaw that MS17-010 fixed, Microsoft saw kernel shellcode resembling DOUBLEPULSAR, and Cisco Talos said it used ETERNALBLUE for access and the DOUBLEPULSAR backdoor to run its payload (Confirmed [20][64][65]). Microsoft shipped the fix for Windows XP, Windows 8 and Windows Server 2003, otherwise limited to custom support, on 13 May, calling it a "highly unusual step", and on 22 May, in an update to the same post, released a Malicious Software Removal Tool update that detects WannaCrypt (Confirmed [21]). The UK National Audit Office found at least 81 of 236 NHS trusts in England and 603 other NHS organisations infected, with 6,912 cancelled appointments recorded and more than 19,000 estimated, and tied the infections to unpatched or unsupported Windows (Confirmed [44]). The US publicly attributed WannaCry to North Korea on 19 December 2017 (Confirmed [46]). That attribution and the government record that followed have their home in North Korea-Attributed Threat Actors, and the outbreak itself, its spread, kill switch, damage and charges, in Part 6 of The Zero-Day Trade and Its Fallout (Demonstrated [32]); the defender guidance from these sources is in Part 11.

NotPetya, in one paragraph

NotPetya began in Ukraine on 27 June 2017 and spread to 64 other countries; some infections started from the M.E.Doc accounting software's updater, which CISA says carried a backdoor as early as 14 April 2017 (Confirmed [45][23]). Microsoft and CISA describe lateral movement by credential theft, PsExec and WMI, and by the EternalBlue and EternalRomance exploits against unpatched hosts, then a master boot record overwrite, a scheduled reboot and cleared event logs; CISA calls credential theft its primary means of spread and says it behaves more like destructive malware than ransomware (Confirmed [45][23]). The US and UK attributed it to the Russian military on 15 February 2018, the White House calling it the most destructive and costly cyber-attack in history (Confirmed [50][51]), and a 2020 indictment of six GRU Unit 74455 officers alleges nearly $1 billion in losses to three victims (Confirmed [52], allegations). The Russian services named in that record are covered in Russia-Attributed Threat Actors. The full record, including the M.E.Doc vector and the victims' filings, is in Sandworm: The Operations in the Public Record (Demonstrated [32]).

What the government record does not say

No US government statement opened links WannaCry or NotPetya to the NSA (Inferred [46][50]). The US record attributes the attacks to North Korea and to Russia's military; Bossert, asked about it, rejected blaming the NSA and said North Korea had weaponized an existing vulnerability (Confirmed [46]). The claim that the exploits came from the NSA rests on Microsoft's statement of 14 May 2017 and on the leakers' own posts (Confirmed [22] as Microsoft's statement; Inferred for the sourcing).

The tools were not only in the leakers' hands

Two vendor studies show Equation tooling in use before the 2016 leak (Confirmed [69][70]):

- **Buckeye (APT3).** Symantec found Buckeye, which ATT&CK lists as an alias of G0022 APT3, using a DoublePulsar variant from 31 March 2016, more than a year before the April 2017 release, delivered by a tool Symantec calls Bemstour. Bemstour paired CVE-2017-0143 with a zero-day, CVE-2019-0703, which

Symantec reported in September 2018 and Microsoft fixed on 12 March 2019. How Buckeye obtained the tooling is unknown; Symantec's leading hypothesis is reconstruction from captured network traffic (Confirmed [69]; Demonstrated [77] for the alias).

- **APT31.** Check Point found that APT31's "Jian" exploit for CVE-2017-0005, which Lockheed Martin's incident response team reported to Microsoft, is a clone of the Equation "EpMe" exploit from the DanderSpritz framework. Jian's embedded exploit carries an October 2014 timestamp, and APT31 used it from at least 2015 until the March 2017 patch; Check Point says APT31 had EpMe's files more than two years before the Shadow Brokers published them in "Lost in Translation" in April 2017. A second exploit, EpMo, was silently patched in May 2017 and Check Point found no CVE for it. Bug collision remains possible but less likely (Confirmed [70]). ATT&CK lists APT31 as an alias of G0128 ZIRCONIUM (Demonstrated [77]). China-attributed groups are covered in China-Attributed Threat Actors.

The long tail

Exploitation did not end with 2017. ESET telemetry shows EternalBlue attempts fell to hundreds per day after WannaCry, climbed again from September 2017, and peaked in mid-April 2018 above the 2017 peaks, possibly tied to Satan ransomware; the article gives no exact figures (Confirmed [73]). ATT&CK's T1210 page names EternalBlue, EternalRomance or MS17-010 in procedures for Ember Bear, Threat Group-3390, Tonto Team, Wizard Spider, campaign C0064, and the software Emotet, InvisiMole, Lucifer, NotPetya, PoshC2, TrickBot and Bad Rabbit (Confirmed [74]). The joint FBI, CISA and NSA advisory AA24-249A of 5 September 2024 on GRU Unit 29155, a unit covered in Russia-Attributed Threat Actors, lists "Use of EternalBlue" as a post-exploitation observation (Confirmed [79]). ATT&CK campaign C0064, AI-Assisted Breach of Mexico's Government Infrastructure (December 2025 to February 2026), records that the adversary tasked an AI coding agent with attempting to exploit the EternalBlue vulnerability (Confirmed [80]).

Part 8: exploited vulnerabilities

CVE	Product and flaw	Fix	KEV added	CWE (NVD or vendor)	Link to the leaks	Source
CVE-2016-6366	Cisco ASA SNMP remote code execution (EXTRABACON)	ASA fixed releases from August 2016; no fix for PIX or FWSM	2022-05-24	CWE-119	Disclosed by "the alleged Shadow Brokers group"	[11][13][24]
CVE-2016-6367	Cisco ASA command-line flaw (EPICBANANA)	Fixed in 8.4(3) and 9.0(1)	2022-05-24	CWE-119	Disclosed by "the alleged Shadow Brokers group"	[12][13][24]
CVE-2016-6909	FortiOS cookie-parser buffer overflow	FG-IR-16-023	Not in KEV	Not checked	Not stated by Fortinet	[14][24]
CVE-2017-0143	Windows SMBv1 server remote code execution	MS17-010	2021-11-03	NVD-CWE-noinfo	April 2017 release; also used by Buckeye's Bemstour	[15][17][24][69]
CVE-2017-0144	Windows SMBv1 server remote code execution (CVSS 3.1 8.8, v2 9.3)	MS17-010	2022-02-10	NVD-CWE-noinfo	April 2017 release; listed in TA17-181A for NotPetya	[15][16][23][24]
CVE-2017-0145	Windows SMBv1 server remote code execution	MS17-010	2022-02-10	NVD-CWE-noinfo	April 2017 release; listed in TA17-181A for NotPetya	[15][17][23][24]
CVE-2017-0146	Windows SMBv1 server remote code execution	MS17-010	2022-03-25	NVD-CWE-noinfo	April 2017 release	[15][17][24]
CVE-2017-0147	Windows SMBv1 server information disclosure	MS17-010	2022-05-24	NVD-CWE-noinfo	April 2017 release	[15][17][24]
CVE-2017-0148	Windows SMBv1 server remote code execution	MS17-010	2022-04-06	CWE-20	April 2017 release	[15][17][24]
CVE-2017-7269	IIS 6 flaw behind ExplodingCan (pairing from the MSRC post's 13 June 2017 update [18])	Did not reproduce on supported platforms	2021-11-03 (KEV date only [24])	Not checked	April 2017 release	[18][24]
CVE-2017-0176	Behind one of the three exploits that did not reproduce	Did not reproduce on supported platforms	Not in KEV	Not checked	April 2017 release	[18][24]
CVE-2017-0005	Windows flaw exploited by EpMe and APT31's Jian	March 2017	2022-05-24	Not checked	Equation exploit cloned before the leak	[70][24]
CVE-2017-3881	Cisco IOS and IOS XE Cluster Management Protocol	cisco-sa-20170317-cmp	2022-03-25	Not checked	Found from Vault 7 documents	[71][24]

CVE	Product and flaw	Fix	KEV added	CWE (NVD or vendor)	Link to the leaks	Source
CVE-2019-0703	Windows SMB zero-day paired with CVE-2017-0143 by Bemstour	12 March 2019	2022-05-23	Not checked	Buckeye's use before the leak	[69][24]

All six MS17-010 CVEs carry KEV's known-ransomware-campaign flag; CVE-2016-6366 and CVE-2016-6367 are marked Unknown (Confirmed [24]). The MS17-010 CVEs were rated Critical for all supported Windows releases, with CVE-2017-0147 the information-disclosure member (Confirmed [15]).

The CVE labels for the exploit names disagree across sources. Microsoft's MSRC table maps EternalBlue, EternalChampion, EternalRomance and EternalSynergy only to MS17-010 as a set (Confirmed [18]). Microsoft's 27 June 2017 NotPetya analysis pairs EternalBlue with CVE-2017-0144 and EternalRomance with CVE-2017-0145 (Confirmed [45]). Its 12 May 2017 WannaCry analysis labels EternalBlue CVE-2017-0145 (Confirmed [64]). ATT&CK's Lucifer entry labels both exploits CVE-2017-0144 (Confirmed [81]), and its InvisiMole entry labels EternalBlue CVE-2017-0144 (Confirmed [74]). This study therefore binds the exploits to MS17-010 and gives a per-CVE pairing only where a source states it (Inferred).

Part 9: the policy record

Before the leaks

The equities argument predates both leaks. On 28 April 2014 Michael Daniel wrote that the US had reinvigorated its process for deciding whether to disclose vulnerabilities, that it was biased toward responsible disclosure, and that the government had no prior knowledge of Heartbleed. He listed the considerations weighed: prevalence, risk, potential harm, likelihood of detection, intelligence need, alternatives, time-limited use, chance of rediscovery and patchability (Confirmed [56]). On 14 February 2017, before Vault 7, before MS17-010 and before the April release, Brad Smith proposed a Digital Geneva Convention at the RSA Conference: states would not attack the private sector or critical infrastructure, would not steal intellectual property, would help companies respond to attacks, and would report vulnerabilities to vendors rather than stockpile them. He also proposed an independent attribution body on the model of the IAEA and a neutral technology sector, a "Digital Switzerland" (Confirmed [53]).

After WannaCry

Microsoft's post of 14 May 2017 said the WannaCrypt exploits were "drawn from the exploits stolen from the National Security Agency", that CIA-held vulnerabilities had appeared on WikiLeaks, and that many computers were still unpatched two months after the March fix. It compared the theft to the US military having Tomahawk missiles stolen and renewed the Digital Geneva Convention call for governments to report vulnerabilities to vendors rather than stockpile, sell or exploit them (Confirmed [22], as Microsoft's statement). The page as fetched showed no byline, and its author was not checked. It is a vendor statement, not a US government admission (Inferred [22][46]). The Digital Geneva Convention call came first and was repurposed as a response to WannaCry (Inferred [53][22]).

Three days later, on 17 May 2017, the PATCH Act of 2017 was introduced in the Senate as S.1157 by Senators Schatz, Johnson and Gardner, with a House companion, H.R.2481, from Representative Lieu (Confirmed [57]). It would have created a statutory Vulnerability Equities Review Board, and it defined

classified vulnerability information inappropriately released to the public as not publicly known (Confirmed [57]), which would have kept leaked vulnerabilities inside the process (Inferred [57]). The latest recorded action for S.1157 is referral to committee on 17 May 2017, and it was not enacted (Inferred [58]); the House companion's status record is not cited here.

At the 19 December 2017 attribution briefing Bossert said the government shares about 90 percent of the vulnerabilities it finds and keeps about 10 percent, rejected blaming the NSA, and answered Smith's criticism of stockpiling (Reported [46]: the 90/10 figure is an official assertion that no opened source checks).

The VEP charter

The unclassified Vulnerabilities Equities Policy and Process charter of 15 November 2017 favors disclosure absent a "demonstrable, overriding interest" in using a vulnerability (Confirmed [59]). Its main points (Confirmed [59]):

- it supersedes the 16 February 2010 policy;
- a monthly Equities Review Board of OMB, ODNI, Treasury, State, Justice, DHS, Energy, Defense (with NSA, USCYBERCOM and DC3), Commerce and CIA makes the decisions;
- the White House Cybersecurity Coordinator directs the process, and NSA is the Executive Secretariat;
- an annual report, with an unclassified summary, may go to Congress;
- it covers only newly discovered vulnerabilities that are not publicly known;
- non-disclosure agreements or memoranda of understanding with partners may constrain disclosure;
- Annex B lists defensive, operational, commercial and international equities.

Rob Joyce published the charter for transparency and promised an annual report; he did not name the Shadow Brokers, referring only to recent incidents of global impact, and rejected claims of massive stockpiles. His stated principles were transparency, fair representation of stakeholders, accountability through regular re-evaluation, and informed public dialogue (Confirmed [60]). Whether any annual report was published was not checked.

Because the charter covers only vulnerabilities that are not publicly known, a vulnerability exposed by a leak such as the Shadow Brokers release falls outside it; the charter does not address the theft of retained exploits; and the NDA and MOU carve-out limits its reach (Inferred [59]). The charter's publication six months after WannaCry is a timing fact; no opened source states a causal link to the leaks (Confirmed [59][60]; Inferred for the absence).

Beyond the United States

The UK NCSC's Ian Levy described the UK Equities Process on 29 November 2018: the default is to tell the vendor, withholding needs an overriding reason, and the Investigatory Powers Commissioner's Office provides oversight. The post does not mention WannaCry or the leaks (Confirmed [61]). On 17 April 2018, 34 companies signed the Cybersecurity Tech Accord, including a pledge not to help governments launch cyberattacks against innocent citizens and enterprises; the announcement places the 2017 RSA call months before WannaCry and NotPetya (Confirmed [54]). The Accord's four principles are to protect all users, oppose cyberattacks on innocent citizens and enterprises, help users protect themselves, and partner with others, including on coordinated vulnerability disclosure (Confirmed [55]).

Part 10: the vulnerability-management view

The leak record is a case study in patch latency more than in zero-days (Inferred). Read as a vulnerability manager would read it:

Measure	Value	Grade
Patch to public exploit release	MS17-010 on 14 March 2017; "Lost in Translation" on 14 April 2017: 31 days	Confirmed [15][7]; Inferred for the interval
Release to vendor triage	15 April 2017, the next day	Confirmed [18]
Patch to WannaCry	59 days	Inferred [15][20]
Patch to NotPetya	105 days	Inferred [15][23]
Patch to KEV listing	CVE-2017-0143: 3 November 2021; CVE-2017-0144: 10 February 2022, almost five years	Confirmed [24]; Inferred for the interval
KEV remediation terms for CVE-2017-0144	Due 10 August 2022; "Apply updates per vendor instructions"	Confirmed [17]
Cisco alert to Cisco advisory	15 to 17 August 2016: two days	Confirmed [11]
Unsupported platforms	XP, Windows 8 and Server 2003 patched on 13 May 2017 only after WannaCry; PIX and FWSM never patched for CVE-2016-6366	Confirmed [21][11]
Protocol retirement	SMBv1 deprecated 2014; "Stop using SMB1" September 2016; not installed by default from version 1709 (October 2017)	Confirmed [67][62]

Four lessons follow. First, a credible public exploit release should move a CVE to the top of the queue on the day of release; the KEV catalog is a floor, not a schedule, and here it trailed the patch by years (Inferred [24]). Second, end-of-support is an exposure in its own right: the NAO tied infection to unpatched or unsupported Windows (Confirmed [44]). Third, SMBv1 removal is not automatic on every estate. Since version 1709 Home and Pro keep the client only until it goes unused for 15 days, clean Windows 11 installs have neither client nor server, Windows Server 2019 and later ship without it, and Microsoft-built Azure Marketplace images cannot enable it; but in-place upgrades of Windows 10 Enterprise, Education and Pro for Workstations do not remove it, so an administrator must decide to (Confirmed [67]). Microsoft strongly recommends against reinstalling it (Confirmed [67]). Fourth, exposure can be measured from outside: Shadowserver publishes an Accessible SMB report of hosts with 445/TCP reachable from the internet, with SMB version fields, and says the service should not be exposed; the page gives no current SMBv1 count (Confirmed [75]).

NVD scores CVE-2017-0144 at CVSS 3.1 8.8 with the vector AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H and CVSS v2 9.3, and assigns no CWE (NVD-CWE-noinfo) to CVE-2017-0143 through CVE-2017-0147 (Confirmed [16][17]). A study or scanner that names a CWE for EternalBlue is going beyond the record (Inferred [17]). See the Vulnerability Management Reference and Vulnerability Prioritization Reference.

Part 11: the defender view

SMB, end to end

- **Patch MS17-010, including on custom-support systems.** Microsoft made the fix available for XP, Windows 8 and Server 2003, and its June 2017 releases covered other heightened-risk flaws on custom-support platforms (Confirmed [21][66]).
- **Remove SMBv1.** Microsoft's workaround for MS17-010 was to disable SMBv1, and SMB1 lacks pre-authentication integrity, secure dialect negotiation, encryption, insecure-guest blocking and modern signing (Confirmed [15][62]).
- **Block SMB at the boundary.** TCP 445, UDP 137 to 138 and TCP 139, per US-CERT and TA17-132A (Confirmed [63][20]).
- **Do not block the WannaCry kill-switch domain.** CISA's advice in 2017 (Confirmed [20]).
- **Keep offline backups and segment.** TA17-132A lists offline backups, segmentation and least privilege (Confirmed [20]).

Credential-based spread

NotPetya shows that patching the exploit is not the whole defense. CISA's mitigations include MS17-010, disabling SMBv1, blocking traffic between workstations, and restricting PsExec and WMI (Confirmed [23]). ATT&CK's mitigations for T1210 in the library's data are M1051 Update Software, M1042 Disable or Remove Feature or Program, M1030 Network Segmentation, M1016 Vulnerability Scanning, M1019 Threat Intelligence Program, M1026 Privileged Account Management, M1048 Application Isolation and Sandboxing and M1050 Exploit Protection (Confirmed [77]).

Detection that shipped with the leak

- **Signatures.** Talos had coverage for two of the SMB exploits before the April release and listed Snort SIDs 41978, 42255 and 42256; for WannaCry it published SIDs 42329 to 42332, 42340 and 41978 (Confirmed [19][65]). Cisco published Snort rule 3:39885 and IPS signature 7655-0 for the ASA SNMP exploit (Confirmed [13]).
- **Implant sweeps.** Countercept's DoublePulsar script, available one day after the dump, sweeps for the implant over SMB and RDP (Confirmed [68]). Symantec published detections for the Longhorn tools: Backdoor.Plexor, Trojan.Corentry and Backdoor.Trojan.LH1 and LH2 (Confirmed [72]).
- **Defender detections.** Ransom:Win32/WannaCrypt from Defender version 1.243.297.0 (Confirmed [64]).

Network devices

The 2016 dump targeted firewalls. Restrict SNMP and change community strings on ASA, as Cisco's workaround advised; retire PIX and FWSM, which never received a fix; disable Telnet in favor of SSH or restrict it with access lists for CVE-2017-3881; and use signed software and Secure Boot against persistent implants of the JETPLOW type (Confirmed [11][13][71]). See Network Security Architecture and Firmware and IoT Security.

Insiders on development networks

The CIA task force's lessons apply to any organization that builds sensitive tooling or code (Inferred [42]):

- **Monitor privileged users.** DevLAN had no user activity monitoring, so the CIA could not size its own loss (Confirmed [42]).
- **Remove residual access.** Schulte's privileges were revoked, but a session he had kept open let him restore them (Confirmed [39]).
- **No shared administrator passwords; compartment the crown jewels.** Both are named root causes, and the better-protected "Gold" folder is the one the task force assessed, with moderate confidence, that WikiLeaks did not hold (Confirmed [42]).
- **Protect logs from the administrators they record.** Hundreds of log files were deleted after the copy (Confirmed [39]).
- **Prepare mitigation packages in advance.** The CIA had none for its exposed tools (Confirmed [42]).

See the Insider Threat Reference and Ransomware Defense Reference.

Part 12: MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0, CAPEC, CWE and D3FEND. Every id was checked against the live MITRE page or the library's data files on 11 November 2026, and every linked page exists in the library's mitre/ tree at main 7a45f0a (Confirmed [25][26][27][74][76][78][80][81]; Demonstrated [77]). The leaks themselves were disclosures, not intrusions with a vendor-documented technique set, so most of the bound techniques belong to the platforms and malware around them (Inferred).

ATT&CK Enterprise techniques

The table holds the techniques ATT&CK records for Equation, WannaCry and NotPetya, one technique the NotPetya advisories support beyond ATT&CK's list, and the techniques this study infers for the Vault 7 theft and the Hive tool from the court record, the task force report and WikiLeaks' Vault 8 page. Tactic names follow the library's v20.0 technique profiles (Demonstrated [77]). Rows marked Inferred are this study's mapping; their ids and names were checked against the library's data (Demonstrated [77]).

Id	Name	Tactic (v20.0)	Where it appears in the record	Source
T1120	Peripheral Device Discovery	Discovery	Equation (G0020); WannaCry, 12 May 2017 (S0366)	[25][26]
T1480.001	Environmental Keying	Stealth	Equation (G0020)	[25]
T1542.002	Component Firmware	Stealth, Persistence	Equation (G0020); Kaspersky's hard-drive firmware module (16 Feb 2015)	[25][1]
T1564.005	Hidden File System	Stealth	Equation (G0020)	[25]
T1210	Exploitation of Remote Services	Lateral Movement	WannaCry, 12 May 2017 (S0366; TA17-132A); NotPetya, 27 Jun 2017 (S0368; TA17-181A); Bad Rabbit, Oct 2017 (S0606); later users on T1210	[26][20][27][23][76][74]
T1570	Lateral Tool Transfer	Lateral Movement	WannaCry (S0366)	[26]

Id	Name	Tactic (v20.0)	Where it appears in the record	Source
T1563.002	RDP Hijacking	Lateral Movement	WannaCry (S0366)	[26]
T1021.002	SMB/Windows Admin Shares	Lateral Movement	NotPetya (S0368); PsExec spread (TA17-181A)	[27][23]
T1016	System Network Configuration Discovery	Discovery	WannaCry (S0366)	[26]
T1018	Remote System Discovery	Discovery	WannaCry (S0366); LAN and internet scanning (Microsoft, 12 May 2017)	[26][64]
T1083	File and Directory Discovery	Discovery	WannaCry (S0366); NotPetya (S0368)	[26][27]
T1518.001	Security Software Discovery	Discovery	NotPetya (S0368)	[27]
T1047	Windows Management Instrumentation	Execution	WannaCry (S0366); NotPetya (S0368; WMIC in TA17-181A and Microsoft, 27 Jun 2017)	[26][27][23][45]
T1569.002	Service Execution	Execution	NotPetya (S0368); PsExec (TA17-181A)	[27][23]
T1053.005	Scheduled Task	Execution, Persistence, Privilege Escalation	NotPetya (S0368); scheduled reboot (Microsoft, 27 Jun 2017)	[27][45]
T1543.003	Windows Service	Persistence, Privilege Escalation	WannaCry (S0366)	[26]
T1078.003	Local Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	NotPetya (S0368)	[27]
T1003.001	LSASS Memory	Credential Access	NotPetya (S0368); credential theft as primary spread (TA17-181A)	[27][23]
T1036	Masquerading	Stealth	NotPetya (S0368)	[27]
T1218.011	Rundll32	Stealth	NotPetya (S0368)	[27]
T1564.001	Hidden Files and Directories	Stealth	WannaCry (S0366)	[26]
T1222.001	Windows Permissions	Defense Impairment	WannaCry (S0366)	[26]
T1685.005	Clear Windows Event Logs	Defense Impairment	NotPetya (S0368); event-log clearing (Microsoft, 27 Jun 2017)	[27][45]
T1090.003	Multi-hop Proxy	Command and Control	WannaCry (S0366)	[26]
T1573.002	Asymmetric Cryptography	Command and Control	WannaCry (S0366)	[26]
T1486	Data Encrypted for Impact	Impact	WannaCry (S0366; TA17-132A); NotPetya (S0368)	[26][20][27]
T1489	Service Stop	Impact	WannaCry (S0366)	[26]

Id	Name	Tactic (v20.0)	Where it appears in the record	Source
T1490	Inhibit System Recovery	Impact	WannaCry (S0366)	[26]
T1529	System Shutdown/Reboot	Impact	NotPetya (S0368); scheduled reboot after MBR overwrite (Microsoft, 27 Jun 2017)	[27][45]
T1195.002	Compromise Software Supply Chain	Initial Access	NotPetya's M.E.Doc updater vector (Microsoft, 27 Jun 2017; TA17-181A); not in ATT&CK's S0368 list, so bound on the advisories alone	[45][23]
T1078	Valid Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	Schulte's use of a kept administrator session, 20 Apr 2016 (Inferred)	[39]
T1098	Account Manipulation	Persistence, Privilege Escalation	Self-granted and restored administrator privileges, Apr 2016 (Inferred)	[39]
T1213.001	Confluence	Collection	DevLAN's Confluence platform, from which WikiLeaks released material (task force, 17 Oct 2017) (Inferred)	[42]
T1213.003	Code Repositories	Collection	DevLAN's Stash code repository (task force, 17 Oct 2017) (Inferred)	[42]
T1070	Indicator Removal	Stealth	Hundreds of log files deleted, 20 Apr 2016 (Inferred)	[39]
T1071.001	Web Protocols	Command and Control	Hive's HTTPS relay through cover domains (Vault 8, 9 Nov 2017) (Inferred)	[35]
T1090	Proxy	Command and Control	Hive's cover-domain relays to a hidden back end (Vault 8) (Inferred)	[35]
T1587.003	Digital Certificates	Resource Development	Hive implant certificates impersonating existing entities, per WikiLeaks (Vault 8) (Inferred; Reported)	[35]

ATT&CK for ICS techniques

ATT&CK maps WannaCry and NotPetya to ATT&CK for ICS as well, because both reached industrial environments through ordinary Windows hosts (Confirmed [26][27]; Inferred for the reason). The names below are from the library's ICS data (Demonstrated [77]). The library has no generated ICS technique pages, so these ids are not linked, and the study's Navigator layer is Enterprise only (Demonstrated [77]).

Id	Name	Tactic	Where it appears	Source
T0866	Exploitation of Remote Services	Initial Access, Lateral Movement	WannaCry (S0366) and NotPetya (S0368), citing MS17-010	[26][27]
T0867	Lateral Tool Transfer	Lateral Movement	WannaCry (S0366) and NotPetya (S0368)	[26][27]
T0828	Loss of Productivity and Revenue	Impact	NotPetya (S0368)	[27]

ATT&CK groups, software and campaigns

Object	Id	Role in the record	Source
Equation	G0020	The cluster Kaspersky tied the 2016 archive to; ATT&CK names no sponsor and no software	[25][2]
Lazarus Group	G0032	ATT&CK's group for WannaCry; named by the UK and in the 2018 complaint	[26][47][48]
Sandworm Team	G0034	ATT&CK's group for NotPetya and Bad Rabbit	[27][76]
APT3	G0022	Buckeye is an alias in ATT&CK; Symantec found its DoublePulsar variant in use from March 2016	[69][77]
ZIRCONIUM	G0128	APT31 is an alias in ATT&CK; Check Point found its Jian exploit cloned from Equation's EpMe	[70][77]
Ember Bear	G1003	T1210 procedure naming MS17-010; AA24-249A records EternalBlue use by GRU Unit 29155	[74][79]
Wizard Spider	G0102	T1210 procedure naming EternalBlue (MS17-010)	[74]
Threat Group-3390	G0027	T1210 procedure naming MS17-010	[74]
Tonto Team	G0131	T1210 procedure naming EternalBlue	[74]
WannaCry	S0366	The May 2017 worm; 16 Enterprise techniques	[26]
NotPetya	S0368	The June 2017 wiper; 14 Enterprise techniques; T1210 names EternalBlue and EternalRomance	[27]
Bad Rabbit	S0606	Spread with EternalRomance, 2017	[76]
Emotet, TrickBot	S0367, S0266	T1210 procedures naming EternalBlue (and EternalRomance for TrickBot)	[74]
Lucifer	S0532	EternalBlue and EternalRomance; ATT&CK labels both CVE-2017-0144	[81]
InvisiMole	S0260	EternalBlue labelled CVE-2017-0144	[74]
PoshC2	S0378	T1210 procedure naming EternalBlue	[74]
Green Lambert	S0690	Attributed by researchers to Longhorn and the Lamberts; no Vault 7 mention in ATT&CK	[78]
AI-Assisted Breach of Mexico's Government Infrastructure	C0064	December 2025 to February 2026; an AI coding agent tasked with an EternalBlue attempt	[80]

CAPEC and CWE

The library's CAPEC data maps these entries to the study's techniques (Demonstrated [77]). No CAPEC entry is supported for the SMBv1 flaws themselves, and none of the library's CAPEC entries maps T1210, T1486, T1490, T1570 or T1003.001 (Confirmed [77]).

Id	Name (library data)	Mapped technique	Fit to this record	Grade
CAPEC-561	Windows Admin Shares with Stolen Credentials	T1021.002	NotPetya's credential theft and PsExec spread (TA17-181A)	Demonstrated for the mapping [77]; Inferred for the fit [23]
CAPEC-560	Use of Known Domain Credentials	T1078	Weak fit: the record describes a kept session, not known-credential reuse	Demonstrated [77]; Inferred [39]
CAPEC-150	Collect Data from Common Resource Locations	T1213 (parent)	Copying the DevLAN archives	Demonstrated [77]; Inferred [39][42]
CAPEC-268	Audit Log Manipulation	T1070	Hundreds of log files deleted	Demonstrated [77]; Inferred [39]
CAPEC-638	Altered Component Firmware	T1542.002	Equation's hard-drive firmware module	Demonstrated [77]; Inferred [1]
CAPEC-186	Malicious Software Update	T1195.002	NotPetya's M.E.Doc updater vector	Demonstrated [77]; Inferred [45][23]
CAPEC-669	Alteration of a Software Update	T1195.002	Same	Demonstrated [77]; Inferred [45][23]

The library's technique profiles also carry ATT&CK's own CAPEC references for the discovery and persistence techniques WannaCry and NotPetya use: CAPEC-309 Network Topology Mapping (T1016), CAPEC-292 Host Discovery (T1018), CAPEC-497 File Discovery (T1083), CAPEC-646 Peripheral Footprinting (T1120), CAPEC-478 Modification of Windows Service Configuration (T1543.003) and CAPEC-581 Security Software Footprinting (T1518.001) (Demonstrated [77]).

CWE	Name (library data)	CVEs	Source
CWE-119	Improper Restriction of Operations within the Bounds of a Memory Buffer	CVE-2016-6366, CVE-2016-6367 (Cisco advisories)	[11][12][77]
CWE-20	Improper Input Validation	CVE-2017-0148 (NVD)	[17][77]
NVD-CWE-noinfo	No CWE assigned	CVE-2017-0143 to CVE-2017-0147 (NVD); the CVE.org CNA records list impact types only	[17]

The Vault 7 theft involved no product vulnerability, so no CWE or CAPEC is bound for a flaw in it (Inferred [39][42]). See the CWE Reference and CAPEC Reference.

D3FEND countermeasures and ATT&CK mitigations

The countermeasures below are the library's D3FEND 1.6.0 mappings to this study's techniques, paired with the guidance in the record they match (Confirmed [77]). T1210 alone maps to 16 D3FEND techniques; the four most relevant to the 2017 guidance are listed (Confirmed [77]).

Countermeasure	Id	Library mapping (selected study techniques)	Guidance in the record it matches	Source
Network Traffic Filtering	D3-NTF	T1210, T1570, T1090.003	Block SMB at the boundary and between workstations	[77][63][23]
Network Traffic Signature Analysis	D3-NTSA	T1210, T1570, T1090.003	Talos and Cisco Snort coverage	[77][19][65][13]
Application Protocol Command Analysis	D3-APCA	T1210, T1570, T1090.003	DoublePulsar's unauthenticated SMB ping, which the Countercept script re-implements	[77][68]
Connection Attempt Analysis	D3-CAA	T1210, T1570	WannaCry's LAN and internet scanning on 445	[77][64]
Decoy File	D3-DF	T1486	Early warning of mass encryption (Inferred pairing)	[77]
File Integrity Monitoring	D3-FIM	T1486	Detect mass file changes (Inferred pairing)	[77]
Restore File	D3-RF	T1486	Offline backups (TA17-132A)	[77][20]
Software Update	D3-SU	T1490, T1542.002, T1195.002	MS17-010; signed software for network devices	[77][15][13]
Asset Vulnerability Enumeration	D3-AVE	T1490, T1542.002, T1195.002	Find unpatched and unsupported hosts	[77][44]
Software Inventory	D3-SWI	T1490, T1542.002, T1195.002	Know where SMBv1 and end-of-support systems remain	[77][67]
Configuration Inventory	D3-CI	T1490	Track SMBv1 state after in-place upgrades	[77][67]
Restore Software	D3-RS	T1490, T1542.002, T1195.002	Rebuild after a wiper	[77][23]
Restore Configuration	D3-RC	T1490	Rebuild after a wiper	[77][23]
Firmware Verification	D3-FV	T1542.002	Secure Boot and signed images against persistent implants	[77][13]
Access Modeling	D3-AM	T1078, T1098	Know who holds administrator rights on development networks	[77][42]
User Account Permissions	D3-UAP	T1078, T1098	Remove residual administrator access; no shared administrator passwords	[77][39][42]
Network Resource Access Mediation	D3-NRAM	T1213.001	Compartment sensitive collaboration spaces	[77][42]
Data Inventory	D3-DI	T1213.003	Know what the code repositories hold and how long it is kept	[77][42]

Two honest gaps remain. In the library's D3FEND data, Software Update and Inbound Traffic Filtering are not mapped to T1210, so the patch-and-retire lesson for the leaked SMB exploits reaches T1210 only through ATT&CK mitigations M1051, M1042, M1030 and M1016 and the others listed in Part 11 (Confirmed [77]). And T1213 (parent), T1070, T1021.002, T1569.002, T1529 and T1685.005 have no D3FEND rows in the library,

so the user activity monitoring the task force asked for has no direct binding here (Demonstrated [77]; Inferred for the gap). See the D3FEND Reference.

Navigator layer

The study's Enterprise techniques are saved as an ATT&CK Navigator layer, navigator/library-layers/nsa-cia-tool-leaks.json, listed on the Navigator layers page. It is pinned to ATT&CK v20 (navigator 4.9, layer format 4.5) and holds every technique of the Enterprise table above, each shown under every tactic in its library technique profile. Scores: 100 where an ATT&CK object maps the technique, 70 where an advisory describes the behavior and the study assigns the id, 40 where the mapping is Inferred. Each entry's comment names the source numbers of this study's Sources table.

Cross-cutting themes

- **Leaks become exploitation dates.** The April 2017 release turned a quiet March patch into a race that many organisations lost within two months (Confirmed [15][20]; Inferred for the framing). See the Vulnerability Management Reference.
- **Old protocols are attack surface.** SMBv1 was deprecated in 2014 and still carried WannaCry and NotPetya in 2017 and EternalBlue use in 2024 (Confirmed [67][79]). See Windows Hardening.
- **Insiders with administrator rights defeat perimeter thinking.** The largest data loss in CIA history came from a developer's kept session on an unmonitored network (Confirmed [39][42]). See the Insider Threat Reference.
- **Attribution falls on the reusers.** Governments named North Korea and Russia's military for the attacks, never the leakers; the leak itself has no named perpetrator on the NSA side (Confirmed [46][50]; Inferred [28][29]). See Threat Actors and United States-Attributed Threat Actors.
- **A supply chain opened the door.** Some NotPetya infections started from M.E.Doc's updater, a trusted channel that foreshadows the build compromise in SolarWinds and SUNBURST (Confirmed [45][23]; Inferred for the comparison).
- **Policy answered with process, not a list.** The VEP charter published how decisions are made, not what is retained, and excluded already-public vulnerabilities (Confirmed [59]; Inferred).

What is overstated and what is understated

- **Overstated: who the Shadow Brokers were.** Kaspersky's evidence is a cryptographic-implementation match to its own Equation cluster, made with high confidence but without any claim about the leakers' identity (Confirmed [2]). ATT&CK names no sponsor for G0020 (Confirmed [25]). Microsoft's "stolen from the National Security Agency" is a vendor's characterization, and no government record opened names the Shadow Brokers (Confirmed [22]; Inferred [28][29]).
- **Overstated: Martin or Pho "as the Shadow Brokers".** Neither DOJ release says so; the links are journalism, and that journalism itself reports that prosecutors never tied Martin to the group (Confirmed [28][29]; Reported [31]).
- **Overstated: "Microsoft patched because of the leak" and "the NSA tipped Microsoft".** MS17-010 credits no finder and marked the flaws not public at release; no opened primary says who reported them (Confirmed [15][18]; Inferred).

- **Overstated: that the leaks created the SMBv1 risk.** Microsoft deprecated SMBv1 in 2014 and published "Stop using SMB1" in September 2016 (Confirmed [67][62]).
- **Overstated: "the CIA lost the majority of its hacking arsenal".** That is WikiLeaks' framing; the task force assessed with moderate confidence that WikiLeaks did not hold the better-protected Gold folder (Reported [33]; Confirmed [42]). WikiLeaks' account that the archive circulated among former US government hackers and contractors, and its vehicle-assassination speculation, find no support in the court record, which attributes the theft to one CIA developer (Reported [33]; Confirmed [39]). Project names in the documents describe capabilities and guides, not operations (Inferred [33][36]).
- **Overstated: "WannaCry used DoublePulsar to break in".** Talos and Microsoft describe EternalBlue for access and DoublePulsar, or similar shellcode, for running the payload (Confirmed [65][64]).
- **Understated: the network-device half of the 2016 dump.** Cisco ASA, PIX and FWSM were the first targets, two Cisco CVEs reached KEV, and PIX and FWSM were never fixed (Confirmed [11][12][24]).
- **Understated: the tooling was out before the leaks.** APT31 had a clone of an Equation exploit by late 2014 and used it from at least 2015, and Buckeye used a DoublePulsar variant from March 2016 (Confirmed [69][70]).
- **Understated: credential theft.** NotPetya spread on patched hosts through stolen credentials and administration tools (Confirmed [23]; Inferred that patched hosts fell to the credential path).
- **Understated: the insider-control failure.** A privileged developer, shared administrator passwords, no user activity monitoring, deleted logs, and an agency that learned of its loss from the publisher about a year later (Confirmed [39][42]).
- **Understated: the long tail.** ESET's April 2018 peak, KEV listings in 2021 and 2022 with known ransomware use, AA24-249A in 2024 and C0064 in 2025 to 2026 (Confirmed [73][24][79][80]).
- **Understated: how little policy changed.** The PATCH Act died in committee, the VEP charter excludes leaked vulnerabilities, and the Digital Geneva Convention became an industry accord rather than a treaty (Inferred [58][59][54]).

Sources

All sources were opened on 11 November 2026. "Primary" means the organization that published the fact; grades apply to the source as used here. Addresses in code format are cited as plain text, not linked, for the reason given in Scope and method.

#	Source	URL	Opened	Grade
1	Kaspersky GReAT, Equation: The Death Star of Malware Galaxy, 16 Feb 2015	securelist.com/equation-the-death-star-of-malware-galaxy/68750/	2026-11-11	Confirmed
2	Kaspersky GReAT, The Equation giveaway, 16 Aug 2016	securelist.com/the-equation-giveaway/75812/	2026-11-11	Confirmed
3	The Shadow Brokers, Message #1 (August 2016), Steemit repost of 9 Apr 2017 (the group's own claims)	`steemit.com/shadowbrokers/@theshadowbrokers/repost-theshadowbrokers-message-1-august-2016`	2026-11-11	Confirmed (as the group's post)

#	Source	URL	Opened	Grade
4	The Shadow Brokers, Message #5 (October 2016), Steemit repost	steemit.com/shadowbrokers/@theshadowbrokers/repost-theshadowbrokers-message-5-october-2016	2026-11-11	Confirmed (as the group's post)
5	The Shadow Brokers, Message #7 (January 2017), Steemit repost	steemit.com/shadowbrokers/@theshadowbrokers/repost-theshadowbrokers-message-7-january-2017	2026-11-11	Confirmed (as the group's post)
6	The Shadow Brokers, "Don't Forget Your Base", Steemit copy created 9 Apr 2017	steemit.com/shadowbrokers/@theshadowbrokers/don-t-forget-your-base	2026-11-11	Confirmed (as the group's post)
7	The Shadow Brokers, "Lost in Translation", 14 Apr 2017 (timestamp from the Steemit API)	steemit.com/shadowbrokers/@theshadowbrokers/lost-in-translation	2026-11-11	Demonstrated
8	The Shadow Brokers' Steemit account, list of posts	steemit.com/@theshadowbrokers	2026-11-11	Demonstrated
9	Public mirror of the decrypted auction archive, repository metadata only	github.com/x0rz/EQGRP	2026-11-11	Demonstrated
10	Public mirror of the April 2017 archives, repository metadata only	github.com/x0rz/EQGRP_Lost_in_Translation	2026-11-11	Demonstrated
11	Cisco, cisco-sa-20160817-asa-snmp (CVE-2016-6366), 17 Aug 2016	sec.cloudapps.cisco.com/.../cisco-sa-20160817-asa-snmp	2026-11-11	Confirmed
12	Cisco, cisco-sa-20160817-asa-cli (CVE-2016-6367), 17 Aug 2016	sec.cloudapps.cisco.com/.../cisco-sa-20160817-asa-cli	2026-11-11	Confirmed
13	Cisco, The Shadow Brokers EPICBANANA and EXTRABACON Exploits, 17 Aug 2016, updated to 20 Apr 2017	blogs.cisco.com/security/shadow-brokers	2026-11-11	Confirmed
14	Fortinet, FG-IR-16-023, Cookie Parser Buffer Overflow (CVE-2016-6909), 17 Aug 2016	fortiguard.com/psirt/FG-IR-16-023	2026-11-11	Confirmed
15	Microsoft, Security Bulletin MS17-010, 14 Mar 2017	learn.microsoft.com/.../ms17-010	2026-11-11	Confirmed
16	NVD, CVE-2017-0144	nvd.nist.gov/vuln/detail/CVE-2017-0144	2026-11-11	Confirmed
17	NVD CVE API, records for CVE-2017-0143 to CVE-2017-0148 (CVE-2017-0144 shown)	services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2017-0144	2026-11-11	Confirmed
18	Microsoft MSRC (Phillip Misner), Protecting customers and evaluating risk, page dated 15 Apr 2017	microsoft.com/en-us/msrc/blog/2017/04/protecting-customers-and-evaluating-risk	2026-11-11	Confirmed
19	Cisco Talos (Alexander Chiu), Shadow Brokers post of 15 Apr 2017 (served at a 2016 URL path)	blog.talosintelligence.com/2016/08/shadow-brokers.html	2026-11-11	Confirmed
20	CISA, Alert TA17-132A, Indicators Associated With WannaCry Ransomware, 12 May 2017, revised 7 Jun 2018	cisa.gov/.../indicators-associated-wannacry-ransomware	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
21	Microsoft MSRC, Customer guidance for WannaCrypt attacks, 13 May 2017	microsoft.com/en-us/msrc/blog/2017/05/customer-guidance-for-wannacrypt-attacks	2026-11-11	Confirmed
22	Microsoft On the Issues, post on lessons from the WannaCrypt attack, 14 May 2017 (byline not captured)	blogs.microsoft.com/on-the-issues/2017/05/14/...	2026-11-11	Confirmed (as Microsoft's statement)
23	CISA, Alert TA17-181A, Petya Ransomware, 1 Jul 2017, revised 15 Feb 2018	cisa.gov/news-events/alerts/2017/07/01/petya-ransomware	2026-11-11	Confirmed
24	CISA, Known Exploited Vulnerabilities catalog, JSON feed (catalog 2026.11.10)	cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-11	Confirmed
25	MITRE ATT&CK, G0020 Equation (v1.2, modified 31 Jul 2026)	attack.mitre.org/groups/G0020/	2026-11-11	Confirmed
26	MITRE ATT&CK, S0366 WannaCry	attack.mitre.org/software/S0366/	2026-11-11	Confirmed
27	MITRE ATT&CK, S0368 NotPetya	attack.mitre.org/software/S0368/	2026-11-11	Confirmed
28	US Attorney's Office, District of Maryland, Former government contractor sentenced to nine years (Harold T. Martin III), 19 Jul 2019	justice.gov/usao-md/pr/former-government-contractor-sentenced-nine-years-...	2026-11-11	Confirmed
29	DOJ Office of Public Affairs, Former NSA employee sentenced (Nghia Hoang Pho), 25 Sep 2018	justice.gov/opa/pr/former-nsa-employee-sentenced-...	2026-11-11	Confirmed
30	Kaspersky, Investigation report for the September 2014 Equation malware detection incident in the US	securelist.com/investigation-report-for-the-september-2014-...	2026-11-11	Confirmed (as Kaspersky's account)
31	POLITICO (Kim Zetter), on Kaspersky, Martin and the NSA, 9 Jan 2019	politico.com/story/2019/01/09/russia-kaspersky-lab-nsa-cybersecurity-1089131	2026-11-11	Reported
32	TeamStarWolf library, case-studies/ on main (commit 7a45f0a)	github.com/TeamStarWolf/TeamStarWolf/tree/main/case-studies	2026-11-11	Demonstrated
33	WikiLeaks, Vault 7: CIA Hacking Tools Revealed ("Year Zero" press release), 7 Mar 2017	wikileaks.org/ciav7p1/	2026-11-11	Confirmed (date); Reported (descriptions)
34	WikiLeaks, Vault 7 release index	wikileaks.org/vault7/	2026-11-11	Confirmed (dates); Reported (descriptions)
35	WikiLeaks, Vault 8 (Hive source), 9 Nov 2017	wikileaks.org/vault8/	2026-11-11	Confirmed (publication and Hive design); Reported (WikiLeaks' claims)
36	WikiLeaks, Weeping Angel "Extending" user guide, dated 28 Feb 2014, as published	`wikileaks.org/vault7/document/EXTENDING_User_Guide/`	2026-11-11	Confirmed (as published)
37	CIA, Statement on claims by WikiLeaks, 8 Mar 2017	cia.gov/stories/story/cia-statement-on-claims-by-wikileaks/	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
38	US Attorney's Office, SDNY, Joshua Adam Schulte charged (superseding indictment), 18 Jun 2018; read from the Internet Archive capture `web.archive.org/web/20251231200253id_/https://www.justice.gov/usao-sdny/pr/joshua-adam-schulte-charged-unauthorized-disclosure-classified-information-and-other`	justice.gov/usao-sdny/pr/joshua-adam-schulte-charged-...	2026-11-11	Confirmed
39	US Attorney's Office, SDNY, Former CIA officer Joshua Adam Schulte sentenced to 40 years, 1 Feb 2024; read from the Internet Archive capture of 31 Dec 2025 (20251231163554)	justice.gov/usao-sdny/pr/former-cia-officer-joshua-adam-schulte-sentenced-...	2026-11-11	Confirmed
40	US Attorney's Office, SDNY, Statement on the espionage conviction of Joshua Schulte, 13 Jul 2022; read from the Internet Archive capture of 28 Jan 2026 (20260128144223)	justice.gov/usao-sdny/pr/statement-us-attorney-damian-williams-...	2026-11-11	Confirmed
41	US Attorney's Office, SDNY, Schulte convicted after trial, 13 Sep 2023; read from the Internet Archive capture of 28 Jan 2026 (20260128101916)	justice.gov/usao-sdny/pr/joshua-adam-schulte-convicted-after-trial-...	2026-11-11	Confirmed
42	CIA WikiLeaks Task Force, Final Report, 17 Oct 2017, redacted excerpt released by Senator Ron Wyden (PDF)	wyden.senate.gov/imo/media/doc/wyden-cybersecurity-lapses-letter-to-dni.pdf	2026-11-11	Confirmed
43	Al Jazeera, CIA blasted for "woefully lax" cybersecurity: report, 16 Jun 2020	aljazeera.com/news/2020/6/16/cia-blasted-for-woefully-lax-cybersecurity-report	2026-11-11	Reported
44	UK National Audit Office, Investigation: WannaCry cyber attack and the NHS, 27 Oct 2017	nao.org.uk/reports/investigation-wannacry-cyber-attack-and-the-nhs/	2026-11-11	Confirmed
45	Microsoft Security, New ransomware, old techniques: Petya adds worm capabilities, 27 Jun 2017	microsoft.com/en-us/security/blog/2017/06/27/...	2026-11-11	Confirmed
46	The White House, Press briefing on the attribution of the WannaCry malware attack to North Korea, 19 Dec 2017 (archived site)	trumpwhitehouse.archives.gov/briefings-statements/press-briefing-on-the-attribution-...	2026-11-11	Confirmed
47	UK Foreign Office, Foreign Office Minister condemns North Korean actor for WannaCry attacks, 19 Dec 2017	gov.uk/government/news/foreign-office-minister-condemns-north-korean-actor-...	2026-11-11	Confirmed
48	DOJ, North Korean regime-backed programmer charged (Park Jin Hyok), 6 Sep 2018; Internet Archive capture of 4 Feb 2025	web.archive.org/web/20250204113113/https://www.justice.gov/opa/pr/north-korean-regime-backed-...	2026-11-11	Confirmed (allegations)
49	US Treasury, press release sm774, designation of Lazarus Group, Bluenoroff and Andariel, 13 Sep 2019	home.treasury.gov/news/press-releases/sm774	2026-11-11	Confirmed
50	The White House, Statement from the Press Secretary on NotPetya, 15 Feb 2018 (archived site)	trumpwhitehouse.archives.gov/briefings-statements/statement-press-secretary-25/	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
51	UK Foreign Office, Foreign Office Minister condemns Russia for NotPetya attacks, 15 Feb 2018	gov.uk/government/news/foreign-office-minister-condemns-russia-for-notpetya-attacks	2026-11-11	Confirmed
52	DOJ, Six Russian GRU officers charged, 19 Oct 2020; Internet Archive capture of 4 Feb 2025	web.archive.org/web/20250204124039/https://www.justice.gov/opa/pr/six-russian-gru-officers-...	2026-11-11	Confirmed (allegations)
53	Microsoft On the Issues, The need for a Digital Geneva Convention, 14 Feb 2017	blogs.microsoft.com/on-the-issues/2017/02/14/need-digital-geneva-convention/	2026-11-11	Confirmed
54	Microsoft On the Issues, 34 companies stand up for cybersecurity with a tech accord, 17 Apr 2018	blogs.microsoft.com/on-the-issues/2018/04/17/...	2026-11-11	Confirmed
55	Cybersecurity Tech Accord, the Accord	cybertechaccord.org/accord/	2026-11-11	Confirmed
56	The White House (Michael Daniel), Heartbleed: understanding when we disclose cyber vulnerabilities, 28 Apr 2014 (archived site)	obamawhitehouse.archives.gov/blog/2014/04/28/...	2026-11-11	Confirmed
57	US Congress, S.1157, PATCH Act of 2017, introduced 17 May 2017 (bill text)	govinfo.gov/content/pkg/BILLS-115s1157is/html/BILLS-115s1157is.htm	2026-11-11	Confirmed
58	US Congress, bill status record for S.1157	govinfo.gov/bulkdata/BILLSTATUS/115/s/BILLSTATUS-115s1157.xml	2026-11-11	Confirmed (record); Inferred (not enacted)
59	The White House, Vulnerabilities Equities Policy and Process for the United States Government (unclassified charter), 15 Nov 2017 (PDF, archived site)	trumpwhitehouse.archives.gov/.../External - Unclassified VEP Charter FINAL.PDF	2026-11-11	Confirmed
60	The White House (Rob Joyce), post on publishing the VEP charter, 15 Nov 2017 (archived site)	trumpwhitehouse.archives.gov/articles/improving-making-vulnerability-equities-...	2026-11-11	Confirmed
61	UK NCSC (Ian Levy), Equities process, 29 Nov 2018	ncsc.gov.uk/blog-post/equities-process	2026-11-11	Confirmed
62	Microsoft (Ned Pyle), Stop using SMB1, TechNet 16 Sep 2016, reposted 10 Apr 2019	techcommunity.microsoft.com/blog/filecab/stop-using-smb1/425858	2026-11-11	Confirmed
63	US-CERT, SMB Security Best Practices, 16 Jan 2017, revised 16 Mar 2017	cisa.gov/news-events/alerts/2017/01/16/smb-security-best-practices	2026-11-11	Confirmed
64	Microsoft Security, WannaCrypt ransomware worm targets out-of-date systems, 12 May 2017	microsoft.com/en-us/security/blog/2017/05/12/...	2026-11-11	Confirmed
65	Cisco Talos, WannaCry analysis, 12 May 2017	blog.talosintelligence.com/wannacry/	2026-11-11	Confirmed
66	Microsoft MSRC (Eric Doerr), June 2017 security update release, 13 Jun 2017	microsoft.com/en-us/msrc/blog/2017/06/june-2017-security-update-release	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
67	Microsoft Learn, troubleshooting article on SMBv1 not being installed by default in Windows	learn.microsoft.com/.../smbv1-not-installed-by-default-in-windows	2026-11-11	Confirmed
68	Countercept (now WithSecureLabs), DoublePulsar detection script, first commit 15 Apr 2017	github.com/WithSecureLabs/doublepulsar-detection-script	2026-11-11	Confirmed
69	Symantec, research on Buckeye's use of Equation tools before the Shadow Brokers leak, 6 May 2019	security.com/threat-intelligence/buckeye-windows-zero-day-exploit	2026-11-11	Confirmed
70	Check Point Research, The story of Jian, 22 Feb 2021	research.checkpoint.com/2021/the-story-of-jian/	2026-11-11	Confirmed
71	Cisco, cisco-sa-20170317-cmp (CVE-2017-3881), 17 Mar 2017	sec.cloudapps.cisco.com/.../cisco-sa-20170317-cmp	2026-11-11	Confirmed
72	Symantec, research linking Longhorn's tools to Vault 7, 10 Apr 2017	security.com/threat-intelligence/longhorn-cyberespionage-vault7	2026-11-11	Confirmed
73	ESET WeLiveSecurity, EternalBlue one year after WannaCryptor, 10 May 2018	welivesecurity.com/2018/05/10/one-year-later-eternalblue-exploit-wannacryptor/	2026-11-11	Confirmed (vendor telemetry)
74	MITRE ATT&CK, T1210 Exploitation of Remote Services (modified 4 Aug 2026)	attack.mitre.org/techniques/T1210/	2026-11-11	Confirmed
75	Shadowserver, Accessible SMB report	shadowserver.org/what-we-do/network-reporting/accessible-smb-report/	2026-11-11	Confirmed
76	MITRE ATT&CK, S0606 Bad Rabbit	attack.mitre.org/software/S0606/	2026-11-11	Confirmed
77	TeamStarWolf library data: data/attack (ATT&CK v20.0 profiles, mitigations, D3FEND 1.6.0 mappings, ICS data), data/weaknesses (CAPEC, CWE) and the generated mitre/ tree, at main 7a45f0a	github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	2026-11-11	Confirmed (MITRE data); Demonstrated (this study's checks)
78	MITRE ATT&CK, S0690 Green Lambert	attack.mitre.org/software/S0690/	2026-11-11	Confirmed
79	FBI, CISA, NSA and partners, joint advisory AA24-249A on GRU Unit 29155, 5 Sep 2024	cisa.gov/news-events/cybersecurity-advisories/aa24-249a	2026-11-11	Confirmed
80	MITRE ATT&CK, C0064 AI-Assisted Breach of Mexico's Government Infrastructure	attack.mitre.org/campaigns/C0064/	2026-11-11	Confirmed
81	MITRE ATT&CK, S0532 Lucifer	attack.mitre.org/software/S0532/	2026-11-11	Confirmed

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Threat Actors, Malware Families, Notable Incidents, CVE Reference
- Vulnerability Management Reference, Vulnerability Prioritization Reference, Incident Response Reference, Detection Rules Reference
- Insider Threat Reference, Ransomware Defense Reference, Windows Hardening, Network Security Architecture, Firmware and IoT Security
- CWE Reference, CAPEC Reference, D3FEND Reference
- Case studies: United States-Attributed Threat Actors, Sandworm: The Operations in the Public Record, The Zero-Day Trade and Its Fallout, North Korea-Attributed Threat Actors, Cyber Operations as Statecraft, Other State-Linked Threat Actors, China-Attributed Threat Actors, Russia-Attributed Threat Actors, SolarWinds and SUNBURST
- Groups: G0020 Equation, G0032 Lazarus Group, G0034 Sandworm Team, G0022 APT3, G0128 ZIRCONIUM, G1003 Ember Bear, G0102 Wizard Spider
- Campaigns: C0064 AI-Assisted Breach of Mexico's Government Infrastructure
- Software: S0366 WannaCry, S0368 NotPetya, S0606 Bad Rabbit, S0532 Lucifer, S0690 Green Lambert
- Techniques: T1210 Exploitation of Remote Services, T1486 Data Encrypted for Impact, T1003.001 LSASS Memory, T1021.002 SMB/Windows Admin Shares, T1542.002 Component Firmware, T1078 Valid Accounts, T1213.003 Code Repositories
- CAPEC: CAPEC-561, CAPEC-560, CAPEC-268, CAPEC-638
- Navigator layers, including this study's layer, nsa-cia-tool-leaks.json